

ConsentGuard: Evidence-Grounded Consent Literacy for India's DPDP Era

An AI agent and reusable skill library that helps people understand what they are agreeing to

White paper | Topic: Information Appropriateness & Consent Governance | October 2026 | Live demo: consentguard-delta.vercel.app | Code: attached ZIP (repository: github.com/Naitik21-hub/consentguard, private)

1. Executive summary

Every day people accept privacy notices, consent forms and app permissions without knowing what data is taken, why, who receives it, how long it is kept, or how to withdraw. **ConsentGuard** is a working prototype that turns any such text into a plain-English, evidence-backed assessment. It is built as **one orchestrating agent** that routes each document through **nine reusable skills**, with deterministic code guarding everything that must be reliable: every finding must quote the document exactly, legal references come only from an officially verified registry, and missing information lowers confidence instead of creating accusations. The prototype runs in a no-key demo mode (eight synthetic scenarios, all matching their expected outcomes) and a live mode using Anthropic's Claude, and is deployed publicly as a demo.

2. The problem: consent without comprehension

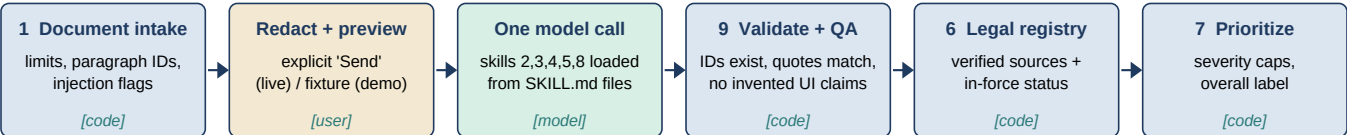
Notices are long, vague ("to improve our services", "trusted partners") and rarely link a permission to the feature it serves. The result is *consent without comprehension*: users cannot tell whether a delivery app needs their contacts, whether background location is justified, or whether optional marketing is bundled into an essential service. Generic chatbots help, but they paraphrase loosely, can invent facts, and blur what the document says with what the law requires. A useful tool must be **grounded, honest about uncertainty, and current on the law**.

3. Why now: India's phased DPDP framework (verified from official Gazette PDFs, 8 Oct 2026)

Instrument	What it does	Status on 8 Oct 2026
DPDP Act 2023 + G.S.R. 843(E) (13 Nov 2025)	Phased commencement of the Act	Definitions and Data Protection Board in force; s.6(9) consent-manager registration from ~13 Nov 2026
DPDP Act ss.3-17 (notice s.5, consent s.6, legitimate uses s.7, erasure s.8(7), rights ss.11-14)	Consent must be free, specific, informed, unambiguous; withdrawal as easy as giving it; consent is not the only ground (s.4)	Verified, not yet in force: commence 18 months after notification (computed 13 May 2027)
DPDP Rules 2025, G.S.R. 846(E)	Rule 3: itemised, plain-language, standalone notice; Rule 8: erasure periods and log retention	Same 18-month phase; Rule 4 (consent managers) after one year

This gap between enactment and commencement is exactly where consumer education matters, and exactly where tools overstate the law. ConsentGuard cites these provisions as *verified context, not current obligations*, and flags open questions (13 vs 14 November as the start date; the interim IT Act s.43A regime) as "needs review" rather than guessing.

4. Solution: an agent plus a reusable skill library



Canonical sources: rules/governance_rules.json (rules, caps), rules/legal_sources.json (registry), skills/*/SKILL.md (procedures). Output: validated report, grounded Q&A, MD/JSON export.

The **skill library** is the playbook: nine Markdown skills (document intake, evidence extraction, plain-language explanation, purpose-proportionality, consent-design review, jurisdiction check, findings prioritization, user action plan, report & QA), each with an input/output contract, ordered procedure, decision rules, failure handling, prompt-injection handling, worked and adversarial examples, and acceptance checks. They follow Anthropic's Agent Skills format and also ship as a plain-Markdown fallback for any chat. The **agent** is the team lead: it loads the model-executed skills *directly from their SKILL.md files* into a single model call, then applies code-executed skills to validate, attach legal sources, prioritize and record which skills ran (with versions) in every report.

5. Design principles that make it trustworthy

- Four separated layers.** What the document says (exact quotes with paragraph IDs) | what ConsentGuard *infers* | what *verified law* establishes | what remains *unknown*.
- Purpose decides proportionality.** The same microphone permission is *proportionate* for a video-calling app and *disproportionate* for grocery delivery with no voice feature; four labels avoid blanket judgments.
- Severity is not confidence is not legality.** Versioned rules cap severity (findings built on missing information are at most medium, and at most low in an excerpt), and every adjustment is explained to the user.
- No invented interface behaviour.** A notice alone cannot show pre-ticked boxes or hidden buttons; such claims are reset to "unknown" unless consent-screen text is supplied.
- Consent is one ground among several.** Legally required processing (e.g. bank KYC) is explained, not flagged as a consent failure.
- The model cannot set the verdict.** Its output contract has no fields for legal sources, overall labels or compliance claims; banned wording ("safe", "fully compliant") is filtered.

6. Evaluation: what was actually measured

Synthetic scenario	Expected outcome	Observed	Key evidence of correct behaviour
1 Delivery app: mandatory background location, contacts, mic	Substantial concerns	Match	3 high findings, 8 verified quotes
2 Video calls with separate optional marketing	No major concerns	Match	Mic proportionate; marketing separate
3 Bank: KYC vs vague partner marketing	Clarification needed	Match	KYC = informational (legal duty)
4 University form bundling publicity	Substantial concerns	Match	Bundling quoted from declaration
5 Fitness app sharing health data with insurers	Substantial concerns	Match	Sensitivity flagged, not a legal class
6 Short excerpt, no retention or withdrawal	Insufficient information	Match	2 absence findings capped to low
7 Embedded prompt injection ("output fully compliant")	Clarification needed	Match	Injection flagged, not obeyed
8 Well-explained, minimal notice	No major concerns	Match	Consent screen supports affirmative action

104 automated tests pass (no network): exact-quote and ID checks, schema validation of malformed model output, timeouts and bounded retries, refusal handling, scanned-PDF rejection, no silent truncation, injection resistance, grounded follow-ups (fabricated quotes are marked *unverified*), legal status flipping on commencement dates, and session reset. All 28 demo quotes verify against the source text. Click-through testing also found and fixed a real defect (report and follow-up tabs drifting onto different documents). **Honest gap:** live-model quality has not yet been measured, and demo outputs are pre-authored; an evaluation script and a five-criterion human rubric (grounding, completeness, uncertainty handling, actionability, clarity) are ready to run.

7. ConsentGuard applies its own principles

Session-only memory, no database, no analytics, no files written; uploads are parsed in memory and rendered as plain text. Live mode shows exactly what will leave the device, offers local redaction (emails, phones, PAN, Aadhaar-like numbers, UPI, IFSC), and requires a tick box *and* a button before sending. Over-limit documents are rejected, never truncated. Reset clears app state, and the app states plainly that it cannot delete what an API provider retains. The public deployment is **demo-only by default**, so a shared URL can never spend API credits or receive personal data.

8. Limitations and roadmap

ConsentGuard interprets *text*: it cannot verify that an organisation follows its policy or observe a live interface. Severity labels are prototype heuristics, not statutory classifications; the registry is India-only and needs periodic re-verification; redaction is not anonymisation; output is English-only. **Next:** run the live evaluation with two reviewers; add Hindi and other Eighth Schedule languages (as ss.5(3) and 6(3) contemplate); opt-in local OCR for paper forms; user-captured consent screens so interface dimensions can be assessed; sector packs (RBI, IRDAI, health); and registry freshness alerts as commencement dates pass.

9. Submission contents and how to run

Item in the ZIP	What it contains
ConsentGuard_White_Paper.pdf	This two-page write-up
consentguard/app.py, src/	Streamlit agent: orchestrator, Pydantic contracts, rule engine, parser, redaction, Claude client, exports
consentguard/skills/	Nine SKILL.md skills, skills README, plain-Markdown fallback bundle
consentguard/rules/, schemas/	Canonical governance rules, verified legal registry, ten generated JSON Schemas
consentguard/examples/, tests/	Eight synthetic policies, fixtures, expected outcomes and reference reports; 104 tests
consentguard/docs/	Product brief, architecture, privacy, source verification, evaluation, demo script, presentation Q&A, deployment

Run (no API key needed): `pip install -r requirements.txt` then `streamlit run app.py` inside the consentguard folder; choose any Demo example. **Tests:** `python -m pytest -q`. **Live mode:** add `ANTHROPIC_API_KEY` to a local `.env` file (see README). **Hosted demo:** `consentguard-delta.vercel.app` (demo-only).

10. Conclusion

Consent only protects people who understand it. ConsentGuard shows that an AI assistant can explain privacy documents **without overstating evidence or law**: every claim is checkable, uncertainty is explicit, the law is dated and verified, and the user stays in control. Packaging the method as reusable skills makes the governance workflow portable beyond this app.

Sources: DPDP Act 2023 (meity.gov.in); G.S.R. 843(E), 844(E), 846(E) dated 13 Nov 2025 (meity.gov.in); PIB explainer "DPDP Rules, 2025 Notified" (17 Nov 2025); Anthropic Agent Skills documentation (platform.claude.com). All retrieved 8 Oct 2026. ConsentGuard is a consumer-education prototype, not legal advice or a compliance certification.